

Vulnerabilities & Threats that Matter

July 2022

Top 5 Takeaways

#1

In July, ransomware activity increased dramatically, with relatively new ransomware like **H0lyGhost**, **Maui**, and **HavanaCrypt** emerging.

#2

Ancient ransomware like **BlackCat**, **MedusaLocker**, and **Redeemer** was back in action, targeting roughly 40 victims. New ransomware variants have started using **rust programming** as a **defense evasion** tactic.

#3

Google chrome's zero-day (CVE-2022-2294) was highly being exploited by Candiru spyware.

#4

KNOTWEED was seen exploiting **zero-day** vulnerabilities in **Microsoft Windows**(CVE-2021-31199, CVE-2021-31201, CVE-2021-36948, CVE-2022-22047) and **Adobe**(CVE-2021-28550).

#5

Almost all these attacks were aimed at countries around the globe. Most of the attacks targeted the **United States** and the **United Kingdom**.

Vulnerabilities of the Month	Threat Actors of the Month	Malware of the Month	Top Targeted Countries	Top Targeted Industries	Common MITRE ATT&CK TTPs
					
57	8	8	UK USA Czech-Republic Romania Belgium	Financial Government Transportation	132

Detailed Report

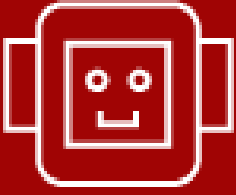
Vulnerabilities of the Month

VENDOR	CVE	PATCH DETAILS
	CVE-2022-32213 CVE-2022-32214 CVE-2022-32215 CVE-2022-32212 CVE-2022-32223 CVE-2022-32222 CVE-2022-2097	https://nodejs.org/en/blog/release/v14.20.0/ https://nodejs.org/en/blog/release/v16.16.0/ https://nodejs.org/en/blog/release/v18.5.0/
	CVE-2022-22047* CVE-2022-22026 CVE-2022-22049 CVE-2022-30216 CVE-2022-22038 CVE-2022-30221 CVE-2022-30222 CVE-2022-22022 CVE-2022-22041 CVE-2022-30206 CVE-2022-30226 CVE-2022-22029 CVE-2022-33678 CVE-2022-33676 CVE-2022-33677 CVE-2021-31199* CVE-2021-31201* CVE-2021-36948*	https://msrc.microsoft.com/update-guide/vulnerability/CVE-2022-22047 https://msrc.microsoft.com/update-guide/vulnerability/CVE-2022-22026 https://msrc.microsoft.com/update-guide/vulnerability/CVE-2022-22049 https://msrc.microsoft.com/update-guide/vulnerability/CVE-2022-30216 https://msrc.microsoft.com/update-guide/vulnerability/CVE-2022-22038 https://msrc.microsoft.com/update-guide/vulnerability/CVE-2022-30221 https://msrc.microsoft.com/update-guide/vulnerability/CVE-2022-30222 https://msrc.microsoft.com/update-guide/vulnerability/CVE-2022-22022 https://msrc.microsoft.com/update-guide/vulnerability/CVE-2022-22041 https://msrc.microsoft.com/update-guide/vulnerability/CVE-2022-30206 https://msrc.microsoft.com/update-guide/vulnerability/CVE-2022-30226 https://msrc.microsoft.com/update-guide/vulnerability/CVE-2022-22029 https://msrc.microsoft.com/update-guide/vulnerability/CVE-2022-33678 https://msrc.microsoft.com/update-guide/vulnerability/CVE-2022-33676 https://msrc.microsoft.com/update-guide/vulnerability/CVE-2022-33677 https://msrc.microsoft.com/update-guide/vulnerability/CVE-2021-31199 https://msrc.microsoft.com/update-guide/vulnerability/CVE-2021-31201 https://msrc.microsoft.com/update-guide/vulnerability/CVE-2021-36948
OpenSSL	CVE-2022-2274	Update to OpenSSL Version 3.0.5 https://github.com/openssl/openssl/commit/4d8a88c134df634ba610ff8db1eb8478ac5fd345
ORACLE	CVE-2019-2725	https://www.oracle.com/security-alerts/alert-cve-2019-2725.html
	CVE-2022-33891	https://spark.apache.org/downloads.html

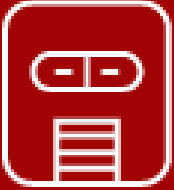
VENDOR	CVE	PATCH DETAILS
	CVE-2022-34230 CVE-2022-34229 CVE-2022-34228 CVE-2022-34227 CVE-2022-34226 CVE-2022-34225 CVE-2022-34224 CVE-2022-34223 CVE-2022-34222 CVE-2022-34221 CVE-2022-34220 CVE-2022-34219 CVE-2022-34218 CVE-2022-34217 CVE-2022-34216 CVE-2022-34215 CVE-2021-28550	https://get.adobe.com/reader
	CVE-2017-2533 CVE-2017-2535 CVE-2017-2534 CVE-2017-6877 CVE-2020-9934 CVE-2022-26706	https://support.apple.com/en-us/HT211289 https://support.apple.com/en-us/HT207797 https://support.apple.com/en-us/HT213256 https://support.apple.com/en-us/HT213257
	CVE-2022-26352	https://www.broadcom.com/support/security-center/attacksignatures/detail?asid=33714
	CVE-2022-26134 CVE-2022-26138 CVE-2022-26136 CVE-2022-26137	https://confluence.atlassian.com/doc/confluence-security-advisory-2022-06-02-1130377146.html https://confluence.atlassian.com/doc/questions-for-confluence-security-advisory-2022-07-20-1142446709.html https://confluence.atlassian.com/security/multiple-products-security-advisory-cve-2022-26136-cve-2022-26137-1141493031.html
	CVE-2022-2294*	https://www.google.com/intl/en/chrome/?standalone=1 Update to Google Chrome version 103.0.5060.114 for Windows, MacOS, and Linux.

*zero-day vulnerability

Threat Actors of the Month

NAME	ORIGIN	TARGET INDUSTRIES	TARGET COUNTRIES
 BlackCat aka ALPHV 	Unknown	Construction engineering, retail, transportation, commercial services, insurance, machinery, professional services, telecommunication	Worldwide
	MOTIVE		
	Information theft and espionage		
	CVEs		

NAME	ORIGIN	TARGET INDUSTRIES	TARGET COUNTRIES
 H0lyGh0st (DEV-0530) 	North Korea	Banks, schools, manufacturing organizations, event and meeting planning companies	Worldwide
	MOTIVE		
	Financial Gain		
	CVEs		
	CVE-2022-26352		

NAME	ORIGIN	TARGET INDUSTRIES	TARGET COUNTRIES
 8220 Gang 	North Korea	Technology, Cloud Service Vendors	Worldwide
	MOTIVE		
	Financial Gain		
	CVEs		
	CVE-2022-26134 CVE-2019-2725		

NAME	ORIGIN	TARGET INDUSTRIES	TARGET COUNTRIES
 APT 29(CozyBear, The Dukes, Group 100, Yttrium, Iron Hemlock, Minidionis, CloudLook, ATK Z, ITG11, Grizzly Steppe, UNC2452, Dark Halo, SolarStorm, StellarParticle, Nobelium, Iron Ritual , Cloaked Ursa) 	Russia	Defense, Energy, Government, Law enforcement, Media, NGOs, Pharmaceutical, Telecommunications, Transportation, Think Tanks and Imagery	Australia, Azerbaijan, Belarus, Belgium Brazil, Bulgaria, Canada, Chechnya, China, Cyprus, Czech, France, Georgia, Germany, Hungary, India, Ireland, Israel, Japan, Kazakhstan, Kyrgyzstan, Latvia, Lebanon, Lithuania, Luxembourg, Mexico, Montenegro, Netherlands, New Zealand, Poland, Portugal, Romania, Russia, Slovakia, Slovenia, Spain, South Korea, Turkey, Uganda, UK, Ukraine, USA, Uzbekistan
	MOTIVE		
	Information theft and espionage		
	CVEs		

NAME	ORIGIN	TARGET INDUSTRIES	TARGET COUNTRIES
 APT 37(Reaper, TEMP.Reaper, Ricochet Chollima, ScarCruft, Thallium, Group 123, Red Eyes, Geumseong121, Venus 121, Hermit, InkySquid, ATK 4, ITG10) 	North Korea	Aerospace, Automotive, Chemical, Financial, Government, Healthcare, High-Tech, Manufacturing, Technology, Transportation, Defense, Education	China, Hong Kong, India, Japan, Kuwait, Nepal, Romania, Russia, South Korea, UK, USA, Vietnam, Czech Republic, Poland, North Korea
	MOTIVE		
	Information theft and espionage		
	CVEs		

NAME	ORIGIN	TARGET INDUSTRIES	TARGET COUNTRIES
 Evilnum(Jointworm, Knockout Spider, TA4563, DeathStalker) 	Unknown	Financial, Government, Retail, Media	Albania, Australia, Belgium, Canada, Cyprus, Czech, Israel, Italy, UK, Ukraine, USA
	MOTIVE		
	Information theft and espionage		
	CVEs		

NAME	ORIGIN	TARGET INDUSTRIES	TARGET COUNTRIES
 KNOTWEED 	Austria	Law firms, Banks, and strategic consultancies	Austria, the United Kingdom, USA, and Panama
	MOTIVE		
	Financial Gain		
	CVEs		
	CVE-2022-22047 CVE-2021-31199 CVE-2021-31201 CVE-2021-28550 CVE-2021-36948		

NAME	ORIGIN	TARGET INDUSTRIES	TARGET COUNTRIES
 Transparent Tribe(APT36, Mythic Leopard) 	Pakistan	Defense, Education, Government, Embassies and Research Organizations	Afghanistan, Australia, Austria, Azerbaijan, Belgium, Botswana, Bulgaria, Canada, China, Czech, Germany, India, Iran, Japan, Kazakhstan, Kenya, Malaysia, Mongolia, Nepal, Netherlands, Oman, Pakistan, Romania, Saudi Arabia, Spain, Sweden, Thailand, Turkey, UAE, UK, USA
	MOTIVE		
	Financial Gain		
	CVEs		



Malware of the Month

NAME	OVERVIEW	TYPE	DELIVERY METHOD
<u>MedusaLocker</u> 	MedusaLocker deploys a PowerShell script to distribute the ransomware throughout the whole network via the Internet Control Message Protocol (ICMP) and Server Message Block (SMB) Protocol after gaining initial access	Ransomware	Vulnerable Remote Desktop Protocol (RDP) configurations or through email phishing.
<u>HavanaCrypt</u> 	HavanaCrypt uses Microsoft web hosting service IP address as the command-and-control (C&C) server to evade detection.	Ransomware	Fake Google Software Update application.
<u>Raspberry Robin</u> 	After gaining initial access, Raspberry Robin establishes persistence by booting at each system startup. The LNK file contains commands for the Windows shell, and another file containing padding data serves as the BAT file	Worm	Spreads via USB devices or through vulnerable QNAP devices
<u>Maui</u> 	Maui ransomware creates encryption keys, instead relying exclusively on manual execution by malicious actors via command-line interface.	Ransomware	Unknown
<u>CloudMensis</u> 	CloudMensis, leverages cloud storage as its command-and-control channel to exfiltrate documents, keystrokes, and screenshots from affected Macs	Spyware	Unknown
<u>Redeemer</u> 	Upon execution, the ransomware initially creates a mutex named "RedeemerMutex" to ensure that only one instance of malware is running on the victim's system. Once its executed, the malware creates a folder, copies itself into the Windows directory with legitimate file names and executes itself as a new process by using the ShellExecuteW() API function.	Ransomware	Unknown

NAME	OVERVIEW	TYPE	DELIVERY METHOD
Candiru 	Candiru collects information once the victim reaches the exploit server. A profile of the victim's browser is compiled and delivered to the attackers.	Spyware	Google Chrome vulnerable to CVE-2022-2294
Konni 	Konni malware as a remote access trojan which was heavily used by APT37 and contains built-in functions to elevate privileges and maintain persistence on the affected host.	Remote Access Trojan	Email Phishing

Targeted Countries



Powered by Bing
© Australian Bureau of Statistics, GeoNames, Microsoft, Navinfo, OpenStreetMap, TomTom

Targeted Industries



Common MITRE ATT&CK TTPs

TA0043: Reconnaissance	TA0042: Resource Development	TA0001: Initial Access	TA0002: Execution	TA0003: Persistence	TA0004: Privilege Escalation	TA0005: Defence Evasion
T1589: Gather Victim Identity Information	T1588: Obtain Capabilities	T1566: Phishing	T1059: Command and Scripting Interpreter	T1547: Boot or Logon Autostart Execution	T1547: Boot or Logon Autostart Execution	T1574: Hijack Execution Flow
T1592: Gather Victim Host Information	T1588.002: Tool	T1566.001: Spearphishing Attachment	T1059.001: PowerShell	T1547.001: Registry Run Keys / Startup Folder	T1547.001: Registry Run Keys / Startup Folder	T1574.002: DLL Side-Loading
T1595: Active Scanning	T1588.006: Vulnerabilities	T1566.002: Spearphishing Link	T1059.003: Windows Command Shell	T1574: Hijack Execution Flow	T1574: Hijack Execution Flow	T1574.001: DLL Search Order Hijacking
T1590: Gather Victim Network Information	T1583: Acquire Infrastructure	T1189: Drive-by Compromise	T1059.005: Visual Basic	T1574.002: DLL Side-Loading	T1574.002: DLL Side-Loading	T1140: Deobfuscate/Decode Files or Information
	T1583.002: DNS Server	T1133: External Remote Services	T1059.008: Network Device CLI	T1574.001: DLL Search Order Hijacking	T1574.001: DLL Search Order Hijacking	T1553: Subvert Trust Controls
	T1583.001: Domains	T1190: Exploit Public-Facing Application	T1053: Scheduled Task/Job	T1053: Scheduled Task/Job	T1055: Process Injection	T1553.005: Mark-of-the-Web Bypass
	T1586: Compromise Accounts	T1091: Replication Through Removable Media	T1053.005: Scheduled Task	T1053.005: Scheduled Task	T1053: Scheduled Task/Job	T1027: Obfuscated Files or Information
	T1584: Compromise Infrastructure	T1078: Valid Accounts	T1569: System Services	T1543: Create or Modify System Process	T1053.005: Scheduled Task	T1027.005: Indicator Removal from Tools
	T1584.004: Server		T1569.002: Service Execution	T1543.003: Windows Service	T1543: Create or Modify System Process	T1564.001: Hidden Files and Directories
	T1608: Stage Capabilities		T1204: User Execution	T1543.004: Launch Daemon	T1543.003: Windows Service	T1070: Indicator Removal on Host
	T1608.004: Drive-by Target		T1204.002: Malicious File	T1068: Exploitation for Privilege Escalation	T1543.004: Launch Daemon	T1070.004: File Deletion
			T1203: Exploitation for Client Execution	T1546: Event Triggered Execution	T1134: Access Token Manipulation	T1055: Process Injection
			T1106: Native API	T1098: Account Manipulation	T1134.001: Token Impersonation/Theft	T1014: Rootkit
			T1072: Software Deployment Tools	T1133: External Remote Services	T1484: Domain Policy Modification	T1134: Access Token Manipulation
			T1204: User Execution	T1556: Modify Authentication Process	T1078: Valid Accounts	T1134.001: Token Impersonation/Theft
			T1204.001: Malicious Link	T1505: Server Software Component	T1548: Abuse Elevation Control Mechanism	T1202: Indirect Command Execution
				T1078: Valid Accounts	T1548.002: Bypass User Account Control	T1564: Hide Artifacts
					T1068: Exploitation for Privilege Escalation	T1548: Abuse Elevation Control Mechanism
					T1546: Event Triggered Execution	T1548.002: Bypass User Account Control
						T1550: Use Alternate Authentication Material
						T1484: Domain Policy Modification
						T1222: File and Directory Permissions Modification
						T1562: Impair Defenses
						T1562.009: Safe Mode Boot
						T1036: Masquerading
						T1036.005: Match Legitimate Name or Location
						T1556: Modify Authentication Process
						T1112: Modify Registry
						T1218: System Binary Proxy Execution
						T1218.007: MsIexec
						T1218.008: Odbccnf
						T1218.011: Rundll32
						T1078: Valid Accounts
						T1497: Virtualization/Sandbox Evasion

TA0006: Credential Access	TA0007: Discovery	TA0008: Lateral Movement	TA0009: Collection	TA0011: Command and Control	TA0010: Exfiltration	TA0040: Impact
T1555: Credentials from Password Stores	T1082: System Information Discovery	T1210: Exploitation of Remote Services	T1560: Archive Collected Data	T1071: Application Layer Protocol	T1567:Exfiltration Over Web Service	T1486: Data Encrypted for Impact
T1555.003: Credentials from Web Browsers	T1016: System Network Configuration Discovery	T1091: Replication Through Removable Media	T1560: Archive Collected Data	T1071.001: Web Protocols	T1567.002: Exfiltration to Cloud Storage	T1489: Service Stop
T1606: Forge Web Credentials	T1057: Process Discovery	T1072: Software Deployment Tools	T1560.003: Archive via Custom Method	T1102: Web Service	T1020: Automated Exfiltration	T1490: Inhibit System Recovery
T1606.001: Web Cookies	T1012: Query Registry		T1560.002: Archive via Library	T1102.002: Bidirectional Communication	T1048: Exfiltration Over Alternative Protocol	T1499: Endpoint Denial of Service
T1539: Steal Web Session Cookie	T1083: File and Directory Discovery		T1560.001: Archive via Utility	T1105: Ingress Tool Transfer	T1041: Exfiltration Over C2 Channel	T1499.004: Application or System Exploitation
T1110: Brute Force	T1007: System Service Discovery		T1119: Automated Collection	T1132: Data Encoding	T1537: Transfer Data to Cloud Account	T1496: Resource Hijacking
T1212: Exploitation for Credential Access	T1033: System Owner/User Discovery		T1005: Data from Local System	T1132.001: Standard Encoding		
T1556: Modify Authentication Process	T1518: Software Discovery		T1025: Data from Removable Media	T1568: Dynamic Resolution		
T1040: Network Sniffing	T1135: Network Share Discovery		T1113: Screen Capture	T1573: Encrypted Channel		
T1003: OS Credential Dumping	T1615: Group Policy Discovery		T1114: Email Collection	T1573.002: Asymmetric Cryptography		
T1528: Steal Application Access Token	T1482: Domain Trust Discovery		T1114.001: Local Email Collection	T1573.001: Symmetric Cryptography		
T1558: Steal or Forge Kerberos Tickets	T1040: Network Sniffing					
	T1049: System Network Connections Discovery					
	T1497: Virtualization/Sandbox Evasion					

Threat Advisories (July 2022)

MONDAY		TUESDAY		WEDNESDAY		THURSDAY		FRIDAY		SATURDAY		SUNDAY	
								1		2		3	
													
4		5		6		7		8		9		10	
													
11		12		13		14		15		16		17	
				 									
18		19		20		21		22		23		24	
													
25		26		27		28		29		30		31	
				 				 					

Click on any of the icons to get directed to the advisory

	Red Vulnerability Report
	Amber Vulnerability Report
	Red Attack Report
	Amber Actor Report
	Red Actor Report

What Next?

Book a free demo with **HivePro Uni5** to check your exposure to this advisory. HivePro Uni5 is a Continuous Threat Exposure Management Solution that proactively reduces an organization's attack surface before it gets exploited.



At Hive Pro we take a long hard look at your vulnerabilities so you can bolster your defenses and fine-tune your offensive cybersecurity tactics.

REPORT GENERATED ON

August 15, 2022 • 4:00 AM

© 2022 All Rights are Reserved by HivePro



More at www.hivepro.com